ANÁLISIS DE RIESGOS

GRC Corporativo

0. Control de Cambios

Versión	Fecha	Descripción	Responsable
1.0	Marzo 2026	Versión inicial del informe de análisis de riesgos.	Pepita Pérez

ÍNDICE

1. Introducción 3
2. Alcance y Contexto 4
   2.1 Alcance del análisis 4
   2.2 Contexto organizativo 5
   2.3 Criterios de riesgo y apetito de riesgo 6
3. Inventario de Activos 7
   3.1 Enfoque de identificación 7
   3.2 Inventario de activos identificados 8
   3.3 Relaciones de dependencia 12
4. Evaluación de Criticidad (BIA) 13
   4.1 Introducción a la evaluación 13
   4.2 Valoración – Capa de Negocio 14
   4.3 Valoración – Capa de Aplicación 15
   4.4 Valoración – Capa Tecnológica 16
   4.5 Valoración – Ubicaciones 17
   4.6 Conclusiones del BIA 17
5. Metodología de Evaluación del Riesgo 18
   5.1 Enfoque metodológico adoptado 18
   5.2 Modelo de estimación del riesgo 19
   5.3 Escala de probabilidad 19
   5.4 Estimación del impacto 20
   5.5 Matriz de riesgo 21
   5.6 Criterios de aceptación del riesgo 21
   5.7 Consideración de controles existentes 21
6. Identificación de Amenazas 22
   6.1 Enfoque adoptado 22
   6.2 Catálogo de amenazas identificadas 23
   6.3 Pares Activo-Amenaza más relevantes 24
7. Análisis y Evaluación de Escenarios 26
   7.1 Enfoque de análisis 26
   7.2 Escenarios analizados 26
   7.3 Resumen de clasificación 32
8. Tratamiento del Riesgo 33
   8.1 Enfoque general 33
   8.2 Plan de tratamiento por escenarios 34
   8.3 Análisis del riesgo residual global 40
   8.4 Integración con el Plan Director de Seguridad 41
9. Conclusiones 42

1. Introducción

XYZ S.L. es una empresa mediana del sector logístico con aproximadamente 60 empleados cuya operativa diaria depende casi en su totalidad del ERP SAP Business One (versión 10.0). No es una dependencia abstracta: en octubre del año pasado, un corte eléctrico de cuatro horas por obras en la calle dejó a los repartidores coordinándose por teléfono y a administración sin poder emitir albaranes ni consultar estados de pedido. Ese incidente no llegó a ser una crisis solo porque duró poco. Es el contexto real en el que se enmarca este análisis.

La infraestructura de XYZ S.L. es híbrida: un servidor HP ProLiant DL380 Gen9 alojado en un CPD local, separado de la oficina principal por un tabique de pladur, sin extinción automática ni replicación geográfica, y servicios en la nube para copias de seguridad y Microsoft 365. Esta configuración aporta flexibilidad, pero también introduce dependencias que no siempre son visibles en el día a día y que tienen consecuencias inmediatas cuando algo falla.

El análisis de riesgos constituye un elemento esencial dentro del sistema de gestión de la seguridad de la información. Permite identificar amenazas realistas, estimar su probabilidad y evaluar el impacto potencial sobre confidencialidad, integridad y disponibilidad. Más que un requisito formal, es el instrumento que permite verificar si los controles ya planificados son proporcionales al riesgo real y detectar posibles desalineaciones entre lo planificado y lo que la arquitectura actual expone.

El análisis se desarrolla en coherencia con el marco documental ya definido por la organización: las Políticas de Seguridad, el Plan Director de Seguridad (horizonte 2026-2028) con sus hallazgos organizativos O1-O8 y técnicos T1-T2, y el Plan de Respuesta ante Incidentes. Esta coherencia permite comprobar si los controles implantados resultan proporcionados al nivel de riesgo real.

Conviene señalar una limitación de partida: parte de la información sobre infraestructura se obtuvo mediante entrevistas informales con el equipo IT (Marcos, administrador de sistemas, y Ana, soporte técnico), por lo que algunas valoraciones tienen un margen de incertidumbre que se refleja en las justificaciones de cada escenario. Con solo dos personas gestionando toda la infraestructura crítica, la concentración de conocimiento técnico es en sí misma un factor de riesgo que reaparece a lo largo del análisis.

Metodológicamente, el análisis se desarrolla conforme a los principios de ISO 31000 y alineado con el enfoque de ISO 27005 para la gestión del riesgo en seguridad de la información. Se adopta un modelo basado en pares activo-amenaza, inspirado en MAGERIT v3, utilizando una aproximación semicuantitativa que combina probabilidad e impacto. Este modelo permite estructurar el análisis sin necesidad de estimaciones económicas complejas, manteniendo coherencia con el alcance del ejercicio.

El objetivo del análisis no es suprimir el riesgo, eso no es viable en un entorno tecnológico dinámico, sino mantenerlo dentro de niveles asumibles por la Dirección. En una organización logística con fuerte dependencia tecnológica, el enfoque adoptado se basa en la proporcionalidad y en la priorización de escenarios críticos, integrando el análisis dentro de un ciclo de mejora continua que refuerce progresivamente la resiliencia operativa de XYZ S.L.

2. Alcance y Contexto

2.1 Alcance del análisis

El presente análisis de riesgos abarca los activos críticos de XYZ S.L. directamente vinculados a la prestación de su servicio logístico principal. Se incluyen activos de negocio, aplicación, tecnología y ubicaciones físicas, considerando que la interrupción o alteración de cualquiera de estos elementos puede afectar de manera directa a la operativa diaria de la organización.

El enfoque adoptado es integral. No se limita a la infraestructura tecnológica, sino que contempla procesos, personas, información y dependencias físicas. En una empresa logística, el riesgo no se materializa únicamente en forma de ciberataque. Puede venir de que el SAI no aguante un corte eléctrico, de que Marcos esté de baja cuando se cae el servidor, o de que el contrato con el proveedor SaaS no tenga cláusula de seguridad y nadie lo haya detectado hasta ahora. Por ello, el alcance incorpora tanto dimensiones técnicas como organizativas.

El horizonte temporal considerado es de tres años (2026-2028), en coherencia con el Plan Director de Seguridad. Este marco facilita priorizar inversiones en seguridad de manera progresiva y mantener coherencia con la planificación estratégica de la organización. Quedan fuera del alcance aquellos sistemas no relacionados con la operativa logística o que no gestionen información relevante para el negocio o el cumplimiento normativo.

2.2 Contexto organizativo

Contexto interno

XYZ S.L. es una empresa mediana del sector logístico con aproximadamente 60 empleados. Su actividad se apoya de forma estructural en el ERP SAP Business One, que gestiona pedidos, planificación de rutas, control de almacén, facturación y seguimiento financiero. La dependencia es elevada: sin ERP no hay albaranes, no hay estados de envío, no se emiten facturas.

La infraestructura tecnológica es híbrida y presenta una concentración relevante de recursos en el CPD local. La base de datos del ERP ocupa ya 380 GB sobre un almacenamiento disponible de 500 GB; en pocos meses habrá que ampliar o limpiar históricos, lo que añade presión operativa sobre una infraestructura que ya acumula deuda técnica. El servidor HP ProLiant DL380 Gen9 tiene seis años y HP dejó de publicar actualizaciones de firmware para ese modelo. El NAS presenta síntomas físicos de degradación desde hace dos semanas (un ruido extraño que Marcos cree que es un disco pero que aún no ha podido revisar). El SAI presentó una alarma de batería el mes pasado; el técnico dijo que aguanta hasta el verano, pero el cambio sigue sin programarse. El hipervisor lleva tres meses sin aplicar una actualización de seguridad crítica por miedo al downtime. Las reglas del FortiGate 60F no se han auditado desde 2022.

La empresa dispone de Políticas de Seguridad formalizadas, Plan Director de Seguridad y Plan de Respuesta ante Incidentes. Esto evidencia una estructura básica de gobernanza. Sin embargo, se identifica una alta concentración operativa en el ERP, la base de datos y el CPD local que incrementa el impacto potencial de cualquier incidente que afecte a estos activos.

Los sistemas on-premise (servidores físicos, almacenamiento, firewall) soportan directamente el ERP, la base de datos y los servicios internos. La organización asume responsabilidad completa sobre su mantenimiento y disponibilidad. Se observa que parte de esta infraestructura no dispone de redundancia total de alimentación eléctrica ni replicación geográfica, lo que incrementa la criticidad del CPD local como punto único de fallo.

La organización utiliza también servicios cloud para ampliar capacidades y mejorar la resiliencia, especialmente en copias de seguridad. Esta dependencia introduce riesgos asociados a terceros: indisponibilidad del proveedor, incidentes de seguridad externos o incumplimientos contractuales. El contrato con el proveedor SaaS no tiene cláusula de seguridad específica y lleva meses pendiente de revisión, con la renovación prevista en marzo.

Contexto externo

El sector logístico es objetivo habitual de campañas de ransomware y fraude por correo electrónico. En septiembre, una empresa logística de la zona sufrió un incidente de phishing que paralizó su operativa varios días. Cuando el CEO de XYZ S.L. preguntó si eso nos podía pasar, la respuesta honesta fue que sí. Esa conversación es uno de los motivos concretos de este análisis.

La organización trata datos identificativos y de contacto de aproximadamente 3.200 clientes activos, sujetos a RGPD. Una brecha de seguridad podría derivar en sanciones económicas, daños reputacionales y obligaciones de notificación ante la AEPD. La gestión de datos sin garantías documentadas adecuadas incrementa el riesgo legal, económico y reputacional.

La utilización de servicios cloud y software de terceros introduce riesgo de cadena de suministro: un incidente en el proveedor puede afectar a disponibilidad o confidencialidad de la información incluso cuando la organización haya implantado controles internos adecuados. Además, la digitalización del seguimiento de envíos amplía la superficie de exposición más allá de la infraestructura interna.

2.3 Criterios de riesgo y apetito de riesgo

La Dirección establece como criterio general que no se aceptarán riesgos que puedan comprometer de forma significativa la continuidad operativa o generar consecuencias legales graves. En términos concretos:

- Compromiso de la continuidad operativa del servicio logístico. Una interrupción prolongada del ERP o de la infraestructura asociada tendría impacto económico inmediato y podría generar incumplimientos contractuales. El corte de octubre, cuatro horas por obras en la calle, es el escenario de referencia que la Dirección no quiere que se repita sin capacidad de respuesta.
- Brechas significativas de datos personales. La protección de la información de clientes es prioritaria. Los escenarios que impliquen acceso no autorizado, pérdida o exposición masiva de datos personales se consideran especialmente críticos, tanto por su impacto legal como por su repercusión reputacional.
- Daños reputacionales relevantes. En un sector competitivo, la pérdida de confianza puede tener consecuencias a medio plazo. Incidentes de seguridad de alto impacto pueden afectar a la percepción de fiabilidad y a la continuidad de contratos.

Se adopta el principio ALARP, clasificando los riesgos en tres categorías: ampliamente aceptables (nivel ≤6), zona intermedia (7-12) e inaceptables (≥13). Dado el perfil tecnológico de la organización (CPD sin redundancia, equipo IT de dos personas, proveedor de fibra único), se adopta un criterio conservador: los riesgos situados en la zona intermedia serán tratados cuando exista incertidumbre relevante o cuando afecten a activos críticos identificados en el BIA. Este criterio conservador responde a la elevada dependencia tecnológica identificada en el contexto interno.

3. Inventario de Activos

3.1 Enfoque de identificación

La identificación de activos se ha realizado siguiendo un enfoque estructurado inspirado en MAGERIT v3, que propone analizar los activos en función de las distintas capas que conforman la arquitectura organizativa. Este enfoque no se limita a enumerar elementos técnicos, sino que busca comprender cómo se conectan entre sí y cómo un incidente en una capa puede propagarse hacia otras, generando efectos en cascada.

Se han considerado cuatro capas principales. La capa de negocio incluye activos directamente vinculados a la actividad principal: información crítica, servicios prestados, contratos, personal clave y activos intangibles como la reputación. Un incidente que afecte a estos elementos impacta directamente en ingresos, cumplimiento legal o confianza de clientes. La capa de aplicación comprende los sistemas de información y bases de datos que soportan los procesos logísticos y financieros; en XYZ S.L. esta capa está fuertemente centralizada en el ERP, lo que genera una elevada dependencia funcional. La capa tecnológica engloba la infraestructura que soporta las aplicaciones: hardware, virtualización, red, almacenamiento y suministro eléctrico. La capa de ubicaciones incluye los espacios físicos donde se desarrollan actividades y se alojan los sistemas.

Se adopta un enfoque top-down, partiendo de los procesos de negocio para identificar los sistemas que los soportan y, posteriormente, la infraestructura que los mantiene operativos. Cada activo se documenta con ID, capa, tipo, nombre, descripción y observaciones. Las observaciones recogen situaciones pendientes de resolución o información contextual obtenida durante las entrevistas con el equipo IT que condicionan directamente la valoración de riesgo.

3.2 Inventario de activos identificados

Capa de Negocio

La capa de negocio representa los activos que generan impacto directo sobre la continuidad y los objetivos estratégicos de la organización. En esta capa se observa que algunos activos, como la reputación o el servicio logístico, no son elementos tecnológicos pero pueden verse gravemente afectados por incidentes que se originen en capas inferiores.

ID	Tipo	Nombre	Descripción	Observaciones
N1	Información	Información de clientes	Datos personales, comerciales y logísticos de ~3.200 clientes activos. Sujeta a RGPD.	Volcado semanal a CSV para el equipo comercial sin cifrar (pendiente de corregir). Vector de exposición activo.
N2	Información	Información financiera	Registros contables, facturación, datos fiscales y documentación	El cierre de enero se retrasó 3 días por un error de exportación del ERP. Hay que revisar el proceso de cuadre.

ID	Tipo	Nombre	Descripción	Observaciones
			económica de la organización.	
N3	Servicio	Servicio logístico principal	Proceso integral de gestión de pedidos, almacenamiento y distribución. Actividad nuclear de la empresa.	Sin ERP la operativa es manual y caótica, como quedó demostrado en el apagón de octubre.
N4	Contrato	Contratos con proveedores	Acuerdos formales con proveedores tecnológicos y logísticos que garantizan el funcionamiento operativo.	Contrato SaaS sin cláusula de seguridad. Legal lleva meses sin revisarlo (renovación en marzo).
N5	Organización	Personal clave IT	Marcos (admin sistemas) y Ana (soporte). Únicos responsables de toda la infraestructura crítica.	Si Marcos coge la baja laboral, nadie más sabe gestionar el hipervisor. Concentración crítica de conocimiento técnico.
N6	Intangible	Imagen y reputación	Confianza de clientes y percepción pública de la organización, activo estratégico altamente sensible.	Tras el incidente al competidor logístico en septiembre, el CEO preguntó si nos podía pasar. Sin respuesta formal.

Observación operativa: La mayor concentración de valor de negocio está en la combinación N1 (Información de clientes) + N3 (Servicio logístico). Un incidente que afecte simultáneamente a ambos activos (por ejemplo, ransomware que cifre el ERP y exfiltre datos de clientes antes del cifrado) generaría impacto operativo y legal de forma concurrente. Es el escenario más crítico del análisis.

Capa de Aplicación

Esta capa agrupa los sistemas de información que soportan directamente los procesos de negocio. Constituyen el núcleo lógico del ecosistema digital. Su compromiso puede afectar simultáneamente a la confidencialidad, integridad y disponibilidad de la información.

ID	Tipo	Nombre	Descripción	Observaciones
A1	Sistema	ERP SAP Business One v10.0	Sistema central que integra procesos logísticos, financieros y administrativos. Licencia 15 usuarios.	Módulo RRHH activo con accesos abiertos aunque nadie lo usa. Pendiente de desactivar desde enero.
A2	Base de datos	Base de datos ERP	Repositorio central donde se almacena la información operativa y financiera. 380 GB / 500 GB disponibles.	Crecimiento continuo: en pocos meses habrá que ampliar o limpiar históricos. Presión operativa activa.
A3	Sistema	Exchange Server 2019 on-premise	Microsoft Exchange 2019. Principal canal de comunicación interno y externo.	Bloqueó 47 adjuntos sospechosos en un solo día la semana pasada. Filtro antispam de serie, nunca ajustado.
A4	Sistema	Active Directory	Servicio de gestión de identidades, autenticación y control de accesos corporativos.	3 cuentas de ex-empleados activas desde hace 4 meses. KPI-02 de las Políticas (revocación <2h) incumplido.
A5	Servicio	Plataforma cloud SaaS	Microsoft 365 y plataforma SaaS de seguimiento de envíos para clientes.	Proveedor sin respuesta al cuestionario de seguridad enviado en diciembre. Sin SLA formal documentado.
A6	Sistema	Sistema de copias de seguridad	Plataforma que genera y custodia las copias de seguridad de los sistemas críticos.	Los backups se comprueban 'cuando hay tiempo'. Último test real de restauración: hace más de un año.

Observación técnica: El ERP (A1) integra módulos logísticos y financieros en una única plataforma, lo que simplifica la gestión operativa pero aumenta la concentración de riesgo. Valorar A2 independientemente de A1 puede parecer artificial, pero cifrar la BD sin tocar la aplicación ERP es técnicamente posible en un movimiento lateral, en ese escenario el ERP estaría activo pero completamente inservible. Esa distinción es relevante para el escenario R2.

Capa Tecnológica

Esta capa representa la infraestructura que soporta físicamente las aplicaciones. Es especialmente relevante en términos de disponibilidad: fallos físicos o de infraestructura pueden afectar a múltiples sistemas de forma simultánea.

ID	Tipo	Nombre	Descripción	Observaciones
T1	Hardware	Servidor HP ProLiant DL380 Gen9	Host físico que soporta las máquinas virtuales críticas del entorno corporativo. Adquirido en 2018.	6 años de antigüedad, fuera de garantía. HP ya no publica firmware para este modelo. Renovación pedida para 2027 sin aprobar.
T2	Virtualización	Hipervisor v7.0.1	Plataforma de virtualización que permite ejecutar múltiples sistemas sobre el servidor físico.	Actualización de seguridad crítica pendiente hace 3 meses. No se aplica por miedo al downtime.
T3	Seguridad	Firewall FortiGate 60F	Controla y filtra el tráfico entrante y saliente de la red corporativa. Gestión interna.	Reglas sin auditar desde 2022. Al menos 12 marcadas 'temporal' llevan años activas. Nadie sabe bien para qué son.
T4	Almacenamiento	Sistema SAN/NAS	Infraestructura de almacenamiento donde residen datos y máquinas virtuales.	Hace ruido extraño desde hace dos semanas. Marcos cree que es un disco pero aún no ha podido mirarlo.
T5	Red	Conectividad a Internet (fibra)	Enlace de comunicación con servicios cloud y correo externo. Un único proveedor.	En febrero se cortó 4 horas por obras. Nadie tenía plan B. El rack está en el pasillo junto a la fotocopiadora.
T6	Infraestructura	Alimentación eléctrica y SAI	Suministro eléctrico e UPS del CPD local. Sin grupo electrógeno permanente.	SAI con alarma de batería degradada el mes pasado. Técnico dice que aguanta hasta el verano. Cambio sin programar.

Observación técnica: La conectividad depende actualmente de un único proveedor de fibra. No existe grupo electrógeno permanente. Esto introduce un riesgo adicional en escenarios de fallo eléctrico prolongado, ya demostrado en el corte de octubre.

Capa de Ubicaciones

La capa de ubicaciones recoge los entornos físicos donde se alojan activos tecnológicos y donde se desarrolla la actividad operativa. El CPD local es especialmente relevante al concentrar dependencias tecnológicas clave.

ID	Tipo	Nombre	Descripción	Observaciones
U1	Ubicación	Oficina principal	Sede operativa (bajo comercial) donde trabaja el personal y desde donde se gestionan los procesos administrativos.	En la última tormenta entró agua por la puerta trasera, cerca del rack de comunicaciones.
U2	Ubicación	CPD local	Centro de procesamiento de datos interno donde se alojan servidores y sistemas críticos.	Separado de la oficina por tabique de pladur. Sin extinción automática por gas ni compartimentación estructural avanzada.

Observación física: El CPD local se encuentra dentro de las instalaciones de la oficina principal y no dispone de compartimentación estructural avanzada ni sistema automático de extinción por gas. La protección actual se basa en control de acceso físico y extintores manuales.

3.3 Relaciones de dependencia

El análisis de dependencias permite comprender cómo un incidente en un activo puede desencadenar efectos indirectos sobre otros. En entornos centralizados como el de XYZ S.L., esta visión resulta especialmente relevante. Se identifican las siguientes dependencias críticas:

Aquí tienes los 9 bullets para pegar directamente:

- **El servicio logístico (N3) depende directamente del ERP (A1).** Toda la gestión de pedidos, planificación de rutas y emisión de documentación se realiza a través del ERP. En caso de indisponibilidad, el personal no dispone de sistema alternativo plenamente operativo, lo que implica paralización casi inmediata de la actividad.
- **El ERP (A1) depende de la base de datos (A2).** La base de datos contiene información operativa y financiera. Una corrupción o cifrado afectaría simultáneamente a integridad y disponibilidad, impidiendo trabajar incluso si la aplicación ERP estuviera técnicamente activa.

- **La base de datos (A2) depende del almacenamiento (T4).** Un fallo físico en el NAS puede generar pérdida de datos o degradación de rendimiento significativa. Este riesgo se ve amplificado por la concentración de múltiples sistemas en el mismo entorno de almacenamiento. El ruido que hace el NAS desde hace dos semanas no es un dato menor.
- **ERP (A1) y correo (A3) dependen de Active Directory (A4).** La autenticación centralizada implica que un fallo en AD bloquearía accesos a múltiples sistemas simultáneamente. Un compromiso de AD podría derivar en escalada de privilegios y afectación transversal. Las 3 cuentas de ex-empleados no desactivadas son un vector de riesgo activo en este nodo.
- **Todos los sistemas on-premise dependen del servidor físico (T1) y del hipervisor (T2).** La virtualización concentra varios servicios en una única infraestructura. Un fallo de hardware o problema en el hipervisor afectaría simultáneamente a ERP, base de datos y servicios internos. El hallazgo T1 del PDS ya identificó esta concentración como vulnerabilidad estructural.
- **Los sistemas internos dependen del suministro eléctrico (T6).** Un corte superior a la autonomía del SAI provocaría apagado forzado del entorno virtualizado, con riesgo de corrupción de datos. El SAI tiene hoy la batería degradada y sin sustitución programada.
- **Los servicios cloud y el correo externo dependen de la conectividad (T5).** La caída de la fibra principal dejaría inoperativos el correo externo y el acceso a servicios SaaS. Como ocurrió en febrero.
- **La continuidad ante incidentes depende del sistema de copias de seguridad (A6).** No es crítico en operación diaria, pero es determinante en recuperación. El Plan de Respuesta ante Incidentes (apartado 4.5, recuperación) asume backups funcionales y recientes. Si eso no es cierto cuando se necesiten, el plan no es ejecutable.
- **Toda la infraestructura tecnológica interna depende físicamente del CPD local (U2).** El CPD constituye un punto único de concentración. Incidentes físicos generarían impacto simultáneo en múltiples capas.

Conclusión de dependencias: Los nodos con mayor concentración de riesgo son el ERP (A1), la base de datos (A2), el servidor físico (T1), la conectividad (T5) y el CPD local (U2). Estos activos no solo son críticos por su valor individual, sino por su capacidad de arrastrar a otros en caso de fallo. Esta visión estructural es clave en la fase de evaluación de escenarios.

4. Evaluación de Criticidad (BIA)

4.1 Introducción a la evaluación

La evaluación de criticidad se ha realizado mediante un enfoque de Business Impact Analysis (BIA), cuyo objetivo es determinar el impacto que tendría la afectación de cada activo sobre la organización. Este análisis permite distinguir entre activos importantes y activos estructurales, aquellos cuya afectación generaría un efecto en cadena, priorizando la protección de los que comprometería en mayor medida los objetivos estratégicos de XYZ S.L.

La valoración considera la tríada clásica de la seguridad de la información. Confidencialidad (C): capacidad de garantizar que la información solo sea accesible por personas autorizadas. Una afectación implica accesos indebidos, filtraciones o divulgación no autorizada. Integridad (I): capacidad de asegurar que la información y los sistemas no sean alterados de forma no autorizada; la pérdida de integridad puede generar decisiones erróneas, facturación incorrecta o manipulación de datos. Disponibilidad (D): capacidad de garantizar que los activos estén accesibles cuando se necesiten; en una organización logística, la indisponibilidad se traduce directamente en paralización operativa y pérdidas económicas inmediatas.

Se utiliza una escala de 1 a 5, donde 1 representa impacto muy bajo y 5 impacto muy alto. La valoración no se ha realizado de forma automática, sino considerando impacto operativo real, consecuencias económicas, obligaciones legales y efectos reputacionales. La suma C + I + D permite obtener una estimación relativa de criticidad entre activos, facilitando su priorización en fases posteriores del análisis.

Valor	Nivel
1	Muy bajo
2	Bajo
3	Medio
4	Alto
5	Muy alto

4.2 Valoración – Capa de Negocio

En la capa de negocio, la evaluación se centra en el impacto directo sobre la actividad principal, los ingresos y las obligaciones legales de la organización.

N1 – Información de clientes (C=5, I=4, D=3): La confidencialidad se valora en nivel máximo por la presencia de datos personales sujetos a RGPD. Una filtración podría implicar sanciones económicas de hasta el 4% de la facturación anual, obligación de notificación a la AEPD y pérdida de confianza comercial. La integridad es alta, ya que datos alterados afectarían a envíos, direcciones y facturación. La disponibilidad se valora en 3 porque, aunque relevante, una indisponibilidad temporal puede gestionarse con información ya emitida o registros recientes, sin paralizar inmediatamente la operativa.

N2 – Información financiera (C=4, I=5, D=4): La integridad alcanza nivel máximo por su impacto en obligaciones fiscales, cierres contables y toma de decisiones estratégicas. El error de exportación de enero que retrasó el cierre tres días ilustra exactamente lo que significa perder integridad en datos financieros. La disponibilidad es alta porque sin facturación se compromete la liquidez. La confidencialidad es relevante por contener información económica sensible, pero no alcanza el máximo nivel de exposición legal que tienen los datos personales.

N3 – Servicio logístico (C=3, I=4, D=5): La disponibilidad es máxima, ya que cualquier interrupción impacta directamente en la actividad principal y genera pérdidas económicas inmediatas. El corte de octubre lo demostró: sin ERP la operativa se paraliza casi inmediatamente. La integridad es alta, porque errores en rutas o pedidos pueden provocar incidencias con clientes. La confidencialidad es importante aunque no estructuralmente crítica.

N4 – Contratos con proveedores (C=3, I=4, D=3): La integridad es alta por las implicaciones legales y económicas derivadas de alteraciones contractuales. La disponibilidad se valora en 3, dado que no se consultan de forma continua en la operativa diaria.

N5 – Personal clave IT (C=1, I=3, D=5): Con solo dos personas en IT, la ausencia de Marcos más de 48 horas convierte cualquier incidente técnico grave en una crisis de continuidad. La disponibilidad se valora en 5 para el administrador de sistemas; esta valoración es inusualmente alta para un activo humano, pero está justificada por la concentración real de conocimiento técnico en una sola persona. Este riesgo fue identificado como hallazgo O2 del PDS.

N6 – Imagen y reputación (C=3, I=4, D=4): Activo intangible cuyo impacto es indirecto pero relevante. No se valora en nivel máximo porque suele verse afectado como consecuencia de incidentes en otras capas, no como causa primaria.

> **Observación:** En la capa de negocio, la dimensión dominante es la disponibilidad del servicio logístico (N3), que se configura como el elemento más crítico para la continuidad operativa.

4.3 Valoración – Capa de Aplicación

En esta capa se concentran activos con efecto estructural, ya que soportan directamente los procesos logísticos y financieros.

A1 – ERP SAP Business One (C=4, I=5, D=5): La integridad y disponibilidad son máximas, ya que cualquier alteración o caída paraliza la organización. La confidencialidad se valora en 4 porque, aunque gestiona información sensible, el repositorio principal de datos es la base de datos, no la aplicación.

A2 – Base de datos ERP (C=5, I=5, D=5): Es el repositorio central de información crítica. Almacena datos personales (C=5/RGPD), financieros (I=5) y operativos (D=5). Se considera el único activo con criticidad máxima absoluta en las tres dimensiones por su concentración estructural. Con 380 GB sobre 500 GB disponibles, la presión de crecimiento añade urgencia operativa que debe resolverse antes de fin de año.

A3 – Exchange Server 2019 (C=3, I=3, D=4): La disponibilidad se valora en 4 por su impacto en coordinación con clientes y proveedores. La confidencialidad e integridad se sitúan en 3, ya que no todo el contenido es crítico. Sin embargo, los 47 adjuntos sospechosos bloqueados en un solo día la semana pasada lo convierten en el vector de amenaza más activo de la organización ahora mismo.

A4 – Active Directory (C=4, I=5, D=5): Activo transversal que controla autenticación y accesos. Un fallo impediría acceso a múltiples sistemas o permitiría accesos indebidos masivos. Se considera nodo crítico de control. Las 3 cuentas de ex-empleados no desactivadas son una vulnerabilidad activa en este activo; el KPI-02 de las Políticas de Seguridad, revocación en menos de 2 horas, no se está cumpliendo.

A5 – Plataforma cloud SaaS (C=3, I=3, D=3): Activo relevante pero no nuclear. Su indisponibilidad afectaría procesos secundarios, pero no detendría completamente la operativa central. El riesgo principal está en el proveedor externo, cuya respuesta al cuestionario de seguridad de diciembre sigue sin llegar.

A6 – Sistema de copias de seguridad (C=3, I=5, D=5): No es crítico en operación diaria, pero la integridad y disponibilidad son máximas en contingencia. Si los backups están cifrados o no son recuperables cuando se necesitan, cualquier incidente previo se vuelve irreversible. El Plan de Respuesta ante Incidentes (apartado 4.5, recuperación) asume backups funcionales y recientes: si eso no es cierto, el plan no es ejecutable. El último test real fue hace más de un año.

> **Observación:** Los activos A2, A1 y A6 configuran el núcleo estructural de resiliencia frente a ransomware y corrupción de datos.

4.4 Valoración – Capa Tecnológica

Esta capa refleja concentración de riesgo técnico y posibles efectos en cascada.

T1 – Servidor HP ProLiant DL380 Gen9 (C=2, I=4, D=5): La disponibilidad es máxima por su impacto transversal sobre el entorno virtualizado. La integridad es alta por su papel en la estabilidad de los sistemas virtualizados. Con 6 años y sin contrato de mantenimiento, el riesgo de fallo físico aumenta de forma progresiva.

T2 – Hipervisor v7.0.1 (C=2, I=4, D=5): Comparte concentración de riesgo con T1. Un fallo afecta simultáneamente a múltiples sistemas virtualizados. La actualización de seguridad pendiente hace 3 meses es una vulnerabilidad explotable desde la red interna.

T3 – Firewall FortiGate 60F (C=4, I=4, D=4): Elemento clave de protección perimetral. Su compromiso puede permitir accesos indebidos o bloquear comunicaciones externas. Las 12 reglas 'temporales' sin auditar desde 2022 representan una superficie de exposición desconocida. El hallazgo T1 del PDS identificó deficiencias en la gestión de dispositivos de red.

T4 – Sistema SAN/NAS (C=4, I=5, D=5): Soporte físico de la base de datos y las VMs. La pérdida o corrupción del almacenamiento implicaría impacto masivo. El ruido detectado en los últimos días eleva la urgencia de revisión.

T5 – Conectividad a Internet (C=2, I=3, D=5): La disponibilidad es máxima, ya que su caída impide acceso a servicios cloud y comunicaciones externas. Depende de un único proveedor, lo que

incrementa el riesgo de indisponibilidad. El corte de febrero —4 horas, sin plan B— demostró la fragilidad de esta dependencia.

T6 – Alimentación eléctrica y SAI (C=1, I=3, D=5): La disponibilidad es máxima: un corte prolongado provocaría apagado forzado del CPD. La autonomía del SAI es limitada y actualmente comprometida por la batería degradada, lo que introduce riesgo real en escenarios de fallo eléctrico.

4.5 Valoración – Ubicaciones

U1 – Oficina principal (C=1, I=2, D=4): Su afectación impacta en operativa presencial, aunque parte de la actividad puede continuar en remoto. La entrada de agua en la última tormenta, cerca del rack de comunicaciones, añade un riesgo físico concreto que debe evaluarse.

U2 – CPD local (C=3, I=5, D=5): Concentra la infraestructura tecnológica crítica. No almacena información visible directamente, pero su afectación física impactaría simultáneamente en múltiples activos tecnológicos. Punto único de concentración sin compartimentación estructural avanzada.

4.6 Conclusiones del BIA

Los activos con mayor impacto estructural son:

Mismo problema, misma causa. Aquí tienes los 6 bullets directamente:

- **Base de datos ERP (A2):** Concentra información personal, financiera y operativa. Único activo con criticidad máxima en las tres dimensiones. Mayor efecto multiplicador sobre otras capas.
- **ERP corporativo (A1):** Núcleo funcional del negocio. Su indisponibilidad paraliza la operativa logística.
- **Sistema de copias de seguridad (A6):** Determinante en escenarios de recuperación ante incidentes graves.
- **Sistema de almacenamiento (T4):** Soporte físico de datos críticos. Su fallo genera impacto masivo e inmediato.
- **CPD local (U2):** Punto de concentración física de la infraestructura.
- **Conectividad (T5) y suministro eléctrico (T6):** Activos de soporte que, aunque no generan valor directo, pueden provocar indisponibilidad total del entorno si fallan.

Estos activos presentan un efecto multiplicador del impacto debido a sus relaciones de dependencia. La criticidad no se debe únicamente a su valor individual, sino a su posición estructural dentro de la arquitectura organizativa. Destacan especialmente T6 (SAI) y T4 (NAS), con criticidad muy alta en disponibilidad y síntomas físicos de degradación activos: son las dos situaciones más urgentes que este análisis identifica.

5. Metodología de Evaluación del Riesgo

5.1 Enfoque metodológico adoptado

El análisis de riesgos se ha desarrollado conforme a los principios establecidos en ISO 31000, que define el riesgo como el efecto de la incertidumbre sobre los objetivos, y alineado con el proceso de apreciación del riesgo descrito en ISO 27005 para la seguridad de la información. Esto implica que el análisis no se limita a identificar amenazas técnicas, sino que vincula cada riesgo con su impacto real sobre la continuidad operativa, el cumplimiento normativo y la sostenibilidad del negocio.

Se adopta un modelo basado en pares activo-amenaza, inspirado en la metodología MAGERIT v3. Este enfoque permite evaluar cómo una amenaza concreta puede afectar a un activo específico, teniendo en cuenta su criticidad y sus relaciones de dependencia. De esta manera, el análisis no se centra en amenazas abstractas, sino en combinaciones específicas que tienen sentido dentro de la arquitectura real identificada en el inventario. Por ejemplo: ransomware afectando a la base de datos ERP es un escenario muy distinto a ransomware afectando al sistema de backups, aunque la amenaza sea la misma.

El proceso seguido comprende las siguientes fases: identificación de activos, valoración de criticidad (BIA), identificación de amenazas relevantes, análisis de escenarios activo-amenaza, evaluación del nivel de riesgo y tratamiento del riesgo.

Nota sobre limitaciones: *La escala semicuantitativa adoptada implica que dos analistas distintos podrían asignar probabilidades ligeramente diferentes a algunos escenarios. Para mitigar esto, se han documentado los criterios de valoración en cada escenario de forma que las decisiones sean revisables y auditables en el siguiente ciclo anual.*

5.2 Modelo de estimación del riesgo

El nivel de riesgo se obtiene como resultado de la combinación de dos variables: probabilidad de ocurrencia, que representa la posibilidad de que una amenaza se materialice en el horizonte temporal considerado; e impacto estimado, que refleja las consecuencias potenciales sobre la organización si dicha amenaza afecta al activo. Se adopta la fórmula clásica: Riesgo = Probabilidad × Impacto.

Se adopta un modelo semicuantitativo, proporcional al tamaño y madurez de XYZ S.L. Una metodología completamente cuantitativa requeriría datos históricos de incidentes de los que la organización no dispone. La honestidad metodológica es más útil que una falsa precisión numérica.

5.3 Escala de probabilidad

La probabilidad se valora mediante una escala de cinco niveles, alineada con el horizonte estratégico de tres años. Esta escala se basa en la frecuencia estimada de ocurrencia de la amenaza en un contexto organizativo similar.

Nivel	Valor	Frecuencia estimada
Muy baja	1	Una vez cada 10 años
Baja	2	Una vez al año
Media	3	Una vez al mes
Alta	4	Una vez a la semana
Muy alta	5	Diaria

Esta escala no pretende representar estadísticas exactas, sino proporcionar una referencia estructurada que permita diferenciar escenarios poco probables de aquellos recurrentes. La valoración considera el sector logístico, el tamaño de la organización y la exposición tecnológica identificada. Por ejemplo: el phishing se valora con probabilidad alta (4) porque es recurrente en el sector y el Exchange de la organización ya experimenta intentos semanales —47 adjuntos bloqueados en un solo día es evidencia objetiva, no estimación—. El incendio se valora como muy baja probabilidad por ausencia de antecedentes y medidas básicas de protección. El fallo eléctrico se valora como baja porque los cortes prolongados son infrecuentes, aunque el estado del SAI eleva la exposición respecto al escenario teórico.

5.4 Estimación del impacto

El impacto se determina combinando la criticidad inicial del activo (obtenida en el BIA) con el grado de degradación que produciría la amenaza sobre las dimensiones C-I-D.

Valor	Nivel de degradación
0	Sin impacto
1	Impacto leve
2	Impacto moderado
3	Impacto significativo
4	Impacto grave
5	Impacto crítico / pérdida total

Con el fin de asegurar coherencia interna y evitar interpretaciones subjetivas, se han definido criterios orientativos específicos para XYZ S.L.:

- **Impacto 1 (Muy bajo):** Interrupción inferior a 30 minutos sin afectación externa ni impacto económico apreciable.
- **Impacto 2 (Bajo):** Interrupción inferior a 2 horas, sin impacto en clientes ni pérdida económica relevante.
- **Impacto 3 (Medio):** Afectación parcial a un departamento o retrasos menores en entregas puntuales.

- **Impacto 4 (Alto):** Interrupción superior a 4 horas o afectación directa a entregas programadas durante la jornada.
- **Impacto 5 (Muy alto):** Paralización total del servicio logístico, pérdida operativa significativa o afectación a datos personales de más de 500 clientes.

Estos criterios permiten vincular la valoración técnica con consecuencias operativas reales dentro del contexto logístico de la organización. El impacto no se basa únicamente en el valor intrínseco del activo, sino en el efecto real que la amenaza concreta tendría sobre él. No todas las amenazas afectan igual a todas las dimensiones: un ransomware impacta principalmente en integridad y disponibilidad; un acceso indebido impacta más en confidencialidad e integridad; un fallo eléctrico afecta esencialmente a disponibilidad.

5.5 Matriz de riesgo

La combinación de probabilidad e impacto genera un nivel de riesgo representado mediante una matriz 5×5. Esta matriz permite visualizar de forma clara la distribución de escenarios según su severidad. En coherencia con el principio ALARP, se establecen tres regiones: riesgo ampliamente aceptable (que no requiere tratamiento adicional más allá de los controles existentes), zona intermedia de tolerabilidad (donde se valorará la conveniencia de implantar medidas adicionales) y riesgo inaceptable (que exige tratamiento obligatorio). La matriz facilita la toma de decisiones y la comunicación de resultados a la Dirección, aunque no sustituye al criterio analítico.

5.6 Criterios de aceptación del riesgo

La Dirección establece los siguientes umbrales orientativos: riesgo ≤6 → ampliamente aceptable; riesgo entre 7 y 12 → zona intermedia, se analizará y en caso de duda se tratará; riesgo ≥13 → inaceptable, requiere tratamiento obligatorio.

Dado el perfil tecnológico de la organización y la criticidad del ERP y de los datos personales gestionados, se adopta un enfoque prudente. Los riesgos situados en la zona intermedia serán objeto de tratamiento cuando afecten a activos críticos identificados en el BIA, aunque no alcancen formalmente el umbral de 13.

5.7 Consideración de controles existentes

La estimación de probabilidad e impacto no se realiza en un escenario teórico sin defensas, sino teniendo en cuenta los controles ya implantados en la organización:

- Políticas de Seguridad formalizadas: MFA obligatorio en servicios críticos, principio de mínimo privilegio, política de correo electrónico.
- Plan de Respuesta ante Incidentes: procedimiento estructurado de actuación ante incidentes, incluyendo fases de detección, contención, erradicación y recuperación.
- Sistema estructurado de copias de seguridad.
- Firewall perimetral FortiGate 60F.
- Control de accesos mediante Active Directory.

Sin embargo, cuando se identifican limitaciones concretas (batería del SAI degradada, backups sin test reciente, hipervisor sin parchear, reglas del firewall sin auditar desde 2022, cuentas de ex-empleados activas en AD) se reflejan en la estimación sin compensarlas artificialmente con los controles teóricos. La diferencia entre control planificado y control efectivo es determinante para la fiabilidad del análisis.

6. Identificación de Amenazas

6.1 Enfoque adoptado

La identificación de amenazas se ha realizado siguiendo un enfoque sistemático alineado con ISO 27005 y con la clasificación de amenazas propuesta en MAGERIT v3. No se ha pretendido construir un catálogo exhaustivo, sino seleccionar aquellas amenazas plausibles y coherentes con el contexto real de una empresa logística mediana como XYZ S.L.

La selección se apoya en cuatro criterios. Primero, la revisión de tipologías habituales de amenaza: ciberataques externos, fallos técnicos, amenazas físicas, errores humanos y riesgos de terceros. Segundo, el análisis del contexto interno: XYZ S.L. depende fuertemente de un ERP centralizado con infraestructura concentrada en un único CPD local, y usa intensivamente el correo electrónico en la gestión operativa, lo que aumenta la exposición a phishing y malware. Tercero, el análisis del contexto externo: el sector logístico ha sido especialmente afectado por campañas de ransomware y fraude por correo (el incidente al competidor de septiembre es evidencia local de ello). Cuarto, la consideración de amenazas técnicas, organizativas, humanas y físicas, ya que los riesgos no se limitan a ataques externos.

Se documentan también las amenazas descartadas. La interceptación de comunicaciones (man-in-the-middle) se valoró inicialmente, pero se descartó al verificarse que las comunicaciones críticas van por canales cifrados (VPN, HTTPS) y que el riesgo residual sería marginal en este contexto. Documentar lo que no está es tan importante como documentar lo que sí está.

6.2 Catálogo de amenazas identificadas

Se identifican las siguientes amenazas principales, coherentes con el perfil de riesgo de la organización:

ID	Amenaza	Descripción
R1	Ransomware	Cifrado malicioso de sistemas y datos críticos con posible solicitud de rescate.
R2	Phishing	Engaño mediante correo electrónico para obtención fraudulenta de credenciales corporativas.
R3	Acceso no autorizado interno	Uso indebido de privilegios por parte de un empleado, ex-empleado o colaborador con acceso activo.
R4	Pérdida de dispositivo portátil	Extravío o robo de equipo con información corporativa almacenada.
R5	Fallo eléctrico prolongado	Interrupción del suministro eléctrico que supera la autonomía del SAI y afecta a sistemas on-premise.
R6	Incendio en CPD	Daño físico a la infraestructura tecnológica alojada en el centro de datos local.

ID	Amenaza	Descripción
R7	Ataque DDoS	Saturación de servicios expuestos a internet mediante tráfico malicioso externo.
R8	Error humano en configuración	Configuración incorrecta de sistemas críticos que genere vulnerabilidades o interrumpa la conectividad.
R9	Brecha en proveedor cloud	Incidente de seguridad en proveedor externo que afecte a datos o servicios corporativos.
R10	Filtración de datos personales	Exposición no autorizada de información de clientes gestionada en el ERP.
R11	Sabotaje interno	Daño intencionado por parte de empleado con acceso legítimo a sistemas críticos.
R12	Malware por correo electrónico	Infección mediante archivo adjunto malicioso no detectado por los filtros de Exchange.

El catálogo cubre amenazas externas intencionadas (ransomware, DDoS), internas intencionadas (sabotaje), accidentales (error humano), físicas (incendio, fallo eléctrico) y derivadas de terceros (brecha en proveedor cloud).

6.3 Pares Activo-Amenaza más relevantes

No todas las amenazas afectan con la misma intensidad a todos los activos. En coherencia con el BIA realizado, se han identificado los escenarios con mayor impacto potencial:

ID Riesgo	Activo afectado	Amenaza	Dimensiones afectadas
R1	A1 – ERP SAP Business One	Ransomware	I, D
R2	A2 – Base de datos ERP	Ransomware	C, I, D
R3	A3 – Exchange 2019	Phishing	C
R4	A4 – Active Directory	Acceso no autorizado interno	C, I
R5	A6 – Sistema de backups	Ransomware sobre backups	I, D
R6	T1 – Servidor HP ProLiant	Fallo eléctrico prolongado	D
R7	U2 – CPD local	Incendio	C, I, D

ID Riesgo	Activo afectado	Amenaza	Dimensiones afectadas
R8	A5 – Plataforma cloud SaaS	Brecha en proveedor	C
R9	N1 – Información de clientes	Filtración de datos personales	C
R10	T3 – Firewall FortiGate 60F	Error humano en configuración	C, D
R11	N3 – Servicio logístico	Ataque DDoS	D
R12	A3 – Exchange 2019	Malware por adjunto	C, I

A continuación se explican los escenarios más críticos:

R1 y R2 – Ransomware sobre ERP y base de datos: Este es el escenario más coherente con el perfil de amenazas en pymes logísticas digitalizadas. El vector de entrada más probable es phishing sobre Exchange que comprometa credenciales y permita movimiento lateral hacia el ERP y la BD. En el ERP, el impacto principal se concentra en disponibilidad e integridad. En la base de datos, el impacto es total: los grupos de ransomware modernos exfiltran datos antes de cifrar, lo que convertiría R2 en un impacto simultáneo sobre C (datos personales de 3.200 clientes), I y D. Por su posición estructural, generaría efecto en cascada sobre el servicio logístico.

R4 – Acceso indebido sobre Active Directory: Dado que AD gestiona autenticación y privilegios de todos los sistemas, su compromiso podría permitir accesos masivos no autorizados o escalada de privilegios. Las 3 cuentas de ex-empleados activas en AD son un vector concreto e inmediato, no hipotético. Incumplen además el KPI-02 de las Políticas de Seguridad(revocación en menos de 2 horas).

R5 – Ransomware sobre backups: Este escenario no paraliza directamente la operativa diaria, pero compromete la capacidad de recuperación. Si los backups están cifrados cuando se necesitan, el impacto de otros incidentes se multiplica. El Plan de Respuesta ante Incidentes (apartado 4.5) asume disponibilidad de backups operativos: si eso no es cierto, el plan no es ejecutable.

R6 – Fallo eléctrico prolongado: Aunque la probabilidad es baja, el contexto del SAI la eleva respecto al escenario teórico. El corte de octubre duró cuatro horas y el SAI aguantó. Hoy, con batería degradada, el mismo corte podría generar un apagado forzado del entorno virtualizado con riesgo de corrupción de datos en la BD.

R10 – Error de configuración en el FortiGate: Con 12 reglas 'temporales' activas desde 2022 y sin procedimiento formal de revisión por pares (gap identificado en el hallazgo T1 del PDS), un cambio urgente en el firewall hecho rápidamente podría dejar un servicio interno expuesto sin que nadie lo detecte.

Del análisis realizado se desprende que los activos con mayor nivel de exposición estructural son el ERP (A1), la base de datos (A2), el sistema de copias de seguridad (A6) y el CPD local (U2). No se trata únicamente de activos con alta puntuación en el BIA, sino de nodos centrales cuya afectación no

impactaría de forma aislada, sino generando efectos en cascada sobre múltiples procesos. La gestión de identidades mediante Active Directory actúa como habilitador de otros riesgos si no se gestiona adecuadamente, y la dependencia de infraestructura on-premise concentrada introduce un riesgo de concentración física que no puede mitigarse únicamente mediante controles lógicos.

7. Análisis y Evaluación de Escenarios

7.1 Enfoque de análisis

Una vez identificados los principales pares activo-amenaza, se procede a su evaluación individual conforme a la metodología definida. Para cada escenario se estima: probabilidad de ocurrencia (considerando el contexto sectorial y los controles existentes); degradación esperada en las dimensiones C-I-D; impacto resultante (considerando la criticidad del activo del BIA y el grado de degradación); y nivel de riesgo como producto de probabilidad e impacto.

La estimación no se realiza en un escenario sin defensas, sino considerando los controles ya implantados. Sin embargo, cuando existe una limitación concreta (SAI con batería degradada, backups sin test reciente, hipervisor sin parchear) se refleja directamente en la estimación, sin compensarla con el control teórico que debería existir.

7.2 Escenarios analizados

Escenario R1 – Ransomware sobre ERP (A1): Probabilidad: 3 (Media) | Deg: C=2, I=5, D=5 | Impacto: Alto (4) | Riesgo: 3×4=12 | Zona intermedia → Tratamiento recomendado

El ERP no está expuesto directamente a internet, pero depende del entorno corporativo y del correo electrónico, que sí lo está. El phishing es recurrente en el sector —47 adjuntos sospechosos bloqueados en un solo día la semana pasada— y el ERP es el núcleo operativo. Un acceso inicial por credenciales comprometidas puede escalar hacia este sistema mediante movimiento lateral en una red sin segmentación estricta (gap técnico T1 del PDS). No se valora con probabilidad alta porque existen firewall, segmentación básica y sistema de backups, pero el riesgo es realista en el horizonte de tres años.

Justificación de degradación: *C=2 (posible acceso previo limitado). I=5 (cifrado total del sistema). D=5 (indisponibilidad completa del ERP).*

Escenario R2 – Ransomware sobre Base de Datos ERP (A2): Probabilidad: 3 (Media) | Deg: C=4, I=5, D=5 | Impacto: Muy alto (5) | Riesgo: 3×5=15 | INACEPTABLE — Tratamiento obligatorio

La base de datos no es accesible directamente desde el exterior, pero depende del ERP y del entorno interno. Si el ERP fuera comprometido, la BD sería el objetivo principal. Los grupos de ransomware modernos exfiltran antes de cifrar, lo que convertiría este escenario en un impacto simultáneo sobre C (datos personales de 3.200 clientes con consecuencias bajo RGPD), I (corrupción total de datos operativos) y D (indisponibilidad completa). Su posición estructural dentro de la arquitectura explica el impacto máximo. La implantación de backups inmutables es la primera medida urgente, especialmente dado el estado actual del NAS.

Justificación de degradación: *C=4 (posible exfiltración previa de datos personales). I=5 (corrupción o cifrado total de datos). D=5 (indisponibilidad del repositorio central).*

Escenario R3 – Phishing sobre Exchange (A3): Probabilidad: 4 (Alta) | Deg: C=3, I=2, D=1 | Impacto: Medio (3) | Riesgo: 4×3=12 | Zona intermedia → Tratamiento recomendado

El correo es el principal canal de comunicación con clientes y proveedores. El volumen de intentos ya es muy alto: 47 adjuntos sospechosos bloqueados en un solo día la semana pasada. El filtro antispam de serie de Exchange nunca ha sido ajustado. La probabilidad es alta porque la amenaza es recurrente en el sector y ya está activa en la organización. El impacto se limita a medio porque el phishing por sí solo no paraliza el ERP (es el escalón previo a R1 y R2, no el incidente final), aunque su efecto en confidencialidad puede ser significativo.

Justificación de degradación: *C=3 (acceso a correos y credenciales). I=2 (alteración limitada de mensajes). D=1 (afectación puntual del servicio).*

Escenario R4 – Acceso no autorizado en AD (A4): Probabilidad: 2 (Baja) | Deg: C=4, I=4, D=3 | Impacto: Alto (4) | Riesgo: 2×4=8 | Zona intermedia → Tratamiento recomendado

No se registran antecedentes de incidentes internos graves y existen controles básicos de acceso en AD. Sin embargo, las tres cuentas de exempleados no desactivadas son una vulnerabilidad activa. Dado que AD concentra privilegios críticos, un uso indebido de credenciales con privilegios elevados tendría efecto transversal sobre múltiples sistemas simultáneamente. Se trata como zona intermedia por el efecto multiplicador de AD sobre el resto de la arquitectura.

Justificación de degradación: *C=4 (acceso indebido a múltiples sistemas). I=4 (modificación de privilegios). D=3 (posible bloqueo de cuentas críticas).*

Escenario R5 – Ransomware sobre Backups (A6): Probabilidad: 2 (Baja) | Deg: C=2, I=5, D=5 | Impacto: Muy alto (5) | Riesgo: 2×5=10 | Zona intermedia → Tratamiento recomendado

Existe configuración de copias con cierto nivel de protección, lo que reduce la probabilidad. Los backups están en la red corporativa y son alcanzables en un movimiento lateral. El impacto es muy alto porque si las copias quedan comprometidas, la capacidad de recuperación ante otros incidentes se ve gravemente afectada. El último test real de restauración fue hace más de un año, lo que no ofrece garantías sobre la capacidad de recuperación actual. El Plan de Respuesta ante Incidentes asume backups operativos: si eso no es cierto, el plan no es ejecutable.

Justificación de degradación: *C=2 (exposición limitada de contenido de backups). I=5 (cifrado o corrupción de copias). D=5 (imposibilidad de recuperación ante otros incidentes).*

Escenario R6 – Fallo eléctrico prolongado (T1): Probabilidad: 2 (Baja) | Deg: D=5 | Impacto: Alto (4) | Riesgo: 2×4=8 | Zona intermedia → Tratamiento recomendado

La sede dispone de suministro eléctrico habitualmente estable, pero el SAI tiene actualmente la batería degradada y sin sustitución programada. El corte de octubre duró cuatro horas por obras en la calle y el SAI aguantó; si ese mismo corte ocurre hoy antes de que se cambie la batería, el apagado forzado del entorno virtualizado podría generar corrupción de datos en la BD. No existe grupo electrógeno permanente que cubra tiempos más prolongados. Un corte superior a la autonomía real del SAI afectaría simultáneamente a múltiples servicios on-premise.

Justificación de degradación: *D=5 (paralización total de sistemas virtualizados y riesgo de corrupción de datos en apagado forzado).*

Escenario R7 – Incendio en CPD (U2): Probabilidad: 1 (Muy baja) | Deg: C=5, I=5, D=5 | Impacto: Crítico (5) | Riesgo: 1×5=5 | AMPLIAMENTE ACEPTABLE

El CPD se ubica en sala dedicada con detección básica de humo y sin antecedentes de incidentes físicos relevantes. Aunque el impacto sería máximo (afectaría simultáneamente a servidor físico, almacenamiento y todos los servicios dependientes), la probabilidad de incendio estructural en el horizonte de tres años se considera muy baja. El riesgo es ampliamente aceptable, aunque se proponen mejoras de bajo coste que mejoran la capacidad de detección y reducen el impacto potencial.

Justificación de degradación: *C=5 (posible pérdida física de soportes con información). I=5 (destrucción de datos sin posibilidad de restauración in-situ). D=5 (interrupción total de servicios on-premise).*

Escenario R8 – Brecha en proveedor cloud SaaS (A5): Probabilidad: 2 (Baja) | Deg: C=4 | Impacto: Alto (4) | Riesgo: 2×4=8 | Zona intermedia → Tratamiento recomendado

El proveedor opera con certificaciones estándar, lo que mantiene la probabilidad en baja. Sin embargo, el proveedor SaaS no ha respondido al cuestionario de seguridad enviado en diciembre y el contrato no tiene cláusula de seguridad específica. La organización no controla directamente su infraestructura, lo que introduce incertidumbre residual. La renovación de contrato prevista en marzo, alineada con el proyecto O6 del PDS, es la oportunidad inmediata para corregir esta situación.

Justificación de degradación: *C=4 (exposición de datos alojados en el tercero, incluyendo posible información de clientes).*

Escenario R9 – Filtración de datos personales (N1): Probabilidad: 3 (Media) | Deg: C=5 | Impacto: Muy alto (5) | Riesgo: 3×5=15 | INACEPTABLE — Tratamiento obligatorio

La información de 3.200 clientes se encuentra centralizada en el ERP y es accesible a múltiples perfiles internos. El volcado semanal a CSV para el equipo comercial sin cifrar es un vector de exposición adicional activo que no está siendo gestionado. Aunque existen controles de acceso, la exposición a phishing y posibles errores humanos mantiene la probabilidad en un nivel medio. El impacto legal bajo RGPD sería significativo: notificación obligatoria a la AEPD, posibles sanciones de hasta el 4% de la facturación anual y daño reputacional con clientes.

Justificación de degradación: *C=5 (exposición masiva de datos personales con consecuencias legales directas bajo RGPD).*

Escenario R10 – Error de configuración en firewall (T3): Probabilidad: 3 (Media) | Deg: C=3, D=3 | Impacto: Medio-alto (3) | Riesgo: 3×3=9 | Zona intermedia → Tratamiento recomendado

La gestión del FortiGate se realiza internamente sin procedimiento formal de revisión por pares documentado, gap identificado en el hallazgo T1 del PDS. Las reglas no se han auditado desde 2022 y hay al menos 12 marcadas como 'temporal' que llevan años activas, sin que nadie tenga claro su propósito. Cambios urgentes en el firewall (exactamente el tipo de cambio que se hace un viernes a las 6 de la tarde cuando algo deja de funcionar) podrían introducir vulnerabilidades temporales o interrumpir conectividad.

Justificación de degradación: *C=3 (posible exposición de servicios internos a internet). D=3 (interrupción de conectividad o bloqueo de servicios legítimos).*

Escenario R11 – Ataque DDoS sobre servicio logístico (N3): Probabilidad: 2 (Baja) | Deg: D=5 | Impacto: Alto (4) | Riesgo: 2×4=8 | Zona intermedia → Tratamiento recomendado

XYZ S.L. tiene un portal de seguimiento de envíos accesible desde internet por los clientes. La organización no es un objetivo prioritario para atacantes sofisticados, lo que mantiene la probabilidad en baja, pero sin mitigación DDoS activa cualquier ataque, incluso modesto, podría resultar disruptivo para un servicio que depende de conectividad externa y que la organización no puede interrumpir sin impacto en clientes.

Justificación de degradación: *D=5 (indisponibilidad del servicio de seguimiento expuesto a internet, con impacto en comunicación con clientes).*

> **Escenario R12 – Malware por adjunto de correo (A3):** Probabilidad: 4 (Alta) | Deg: C=3, I=3 | Impacto: Medio (3) | Riesgo: 4×3=12 | Zona intermedia → Tratamiento recomendado

El correo es el vector más activo ahora mismo en la organización. Los intentos de distribución de malware por adjunto son constantes en pymes del sector logístico. Aunque existen filtros en Exchange, el filtro antispam de serie tiene capacidades limitadas frente a malware polimórfico o adjuntos con macros ofuscadas. La probabilidad es alta porque los intentos ya se están produciendo con regularidad. El impacto se limita a medio porque los filtros actuales bloquean la mayoría, pero la interacción humana sigue siendo el factor determinante: un solo clic en el adjunto equivocado puede ser el punto de entrada de un incidente mayor.

Justificación de degradación: *C=3 (posible robo de información o credenciales). I=3 (modificación de datos o propagación interna).*

7.3 Resumen de clasificación

La distribución de escenarios refleja una concentración de riesgos en torno a los activos más críticos del BIA, lo que confirma la consistencia interna del análisis:

Región	Escenarios	Nivel de riesgo
Inaceptable (≥13)	R2 (Ransomware BD), R9 (Filtración datos)	15 ambos
Zona intermedia (7-12)	R1, R3, R4, R5, R6, R8, R10, R11, R12	8 a 12
Ampliamente aceptable (≤6)	R7 (Incendio CPD)	5

Las cuatro áreas de mayor exposición son: protección de datos personales de clientes (R9), integridad y disponibilidad del ERP y base de datos (R1, R2), gestión de identidades y credenciales (R3, R4, R12) y dependencia de infraestructura tecnológica centralizada (R5, R6, R7). Esta concentración es coherente con los resultados del BIA y las dependencias estructurales identificadas en el inventario.

8. Tratamiento del Riesgo

8.1 Enfoque general

Conforme a la metodología definida y en alineación con ISO 27005, el tratamiento del riesgo se aplica a los escenarios clasificados como inaceptables y a los situados en la zona intermedia, especialmente cuando afectan a activos críticos identificados en el BIA. El objetivo no es eliminar completamente el riesgo, sino reducirlo hasta niveles coherentes con el apetito de riesgo definido por la Dirección.

Las opciones de tratamiento consideradas son: mitigar el riesgo mediante la implantación o refuerzo de controles técnicos, organizativos o físicos; transferir el riesgo mediante contratos, seguros o acuerdos con terceros; evitar el riesgo eliminando la actividad que lo genera (solo en casos excepcionales); y aceptar el riesgo residual cuando el nivel resultante sea coherente con los criterios de la Dirección.

En el caso de XYZ S.L., se adopta un enfoque conservador. Los riesgos que puedan comprometer la continuidad operativa, la integridad del ERP o la protección de datos personales se tratarán de forma obligatoria, independientemente de su ubicación exacta en la matriz.

Las medidas se integran en el Plan Director de Seguridad como líneas de actuación priorizadas. Los proyectos técnicos (EDR, segmentación, backups inmutables, revisión eléctrica) se incorporan al Año 1 del PDS, reforzando y completando los proyectos T1 y T2 ya planificados. Las medidas organizativas (gestión de privilegios, procedimiento de cambios, formación) refuerzan los proyectos O1, O2 y O3. La revisión contractual con proveedores se integra en el proyecto O6.

8.2 Plan de tratamiento por escenarios

I. Riesgos Inaceptables (Nivel inicial ≥ 13)

R2 – Ransomware sobre Base de Datos ERP | Nivel inicial: 15 → Residual objetivo: 6

Medidas propuestas:

- Implantación de EDR en servidores críticos, reforzando el proyecto T1 del PDS.
- Segmentación estricta entre red de usuario y red de servidores para limitar movimientos laterales.
- Backups inmutables en red aislada más copia offline semanal, asegurando la capacidad de recuperación asumida en el Plan de Respuesta ante Incidentes (sección 4.5).
- Pruebas trimestrales reales de restauración documentadas —la única forma de verificar que los backups son realmente recuperables, algo que el plan da por sentado pero que actualmente no existe.
- Revisión trimestral de privilegios en Active Directory.

Justificación técnica: La segmentación reduce la probabilidad de que un compromiso inicial escale hacia la base de datos. El EDR mejora la detección temprana de actividad anómala. Las copias inmutables y las pruebas reales de restauración reducen el impacto efectivo al garantizar recuperación operativa en tiempos asumibles.

> **Urgencia adicional:** La implantación de backups inmutables es la primera medida a ejecutar, dado el estado actual del NAS con síntomas físicos de degradación. Si el disco falla antes de tener backups inmutables operativos, R2 pasa de inaceptable a catástrofe sin recuperación posible.

Resultado esperado: Probabilidad: 3 → 2 | Impacto: 5 → 3 | Riesgo residual: 2×3=6 → Aceptable. Responsable: CISO + Dpto. IT. Plazo: Año 1 (backups inmutables: inmediato). Coste estimado: alto.

R9 – Filtración de datos personales | Nivel inicial: 15 → Residual objetivo: 6

Medidas propuestas:

- MFA obligatorio en ERP y correo, cerrando el gap del KPI-01 de las Políticas de Seguridad v1.1 (objetivo 100% de empleados con MFA).
- Cifrado en reposo de la base de datos, limitando el impacto de accesos físicos o exfiltración parcial.
- Registro centralizado de accesos sensibles para detección temprana de actividad anómala.
- Formación específica en protección de datos, alineada con el proyecto O2 del PDS.
- Revisión periódica de perfiles con acceso a datos personales (N1), reduciendo exposición innecesaria.
- Medida inmediata adicional: cifrar o eliminar el volcado semanal a CSV para el equipo comercial, que actualmente circula sin protección.

Justificación técnica: El MFA reduce la probabilidad de acceso indebido mediante credenciales comprometidas. El cifrado limita el impacto en caso de acceso físico o exfiltración parcial. La revisión de perfiles reduce exposición innecesaria. La monitorización mejora la detección temprana.

Resultado esperado: Probabilidad: 3 → 2 | Impacto: 5 → 3 | Riesgo residual: 2×3=6 → Aceptable. Responsable: DPO + Dpto. Operaciones. Plazo: Año 1. Coste estimado: medio.

II. Riesgos en Zona Intermedia (Nivel inicial entre 7 y 12)

R1 – Ransomware sobre ERP | Nivel inicial: 12 → Residual objetivo: 6

Medidas propuestas: gestión mensual de parches (proyecto T2 del PDS); segmentación interna adicional del ERP (T1 del PDS); simulacros anuales de recuperación conforme al Plan de Respuesta ante Incidentes, sección 4.5.

Justificación técnica: La actualización periódica reduce vectores explotables. La segmentación limita propagación interna. Los simulacros validan tiempos reales de recuperación y detectan gaps en el Plan de Respuesta.

Resultado esperado: Probabilidad: 3 → 2 | Impacto: 4 → 3 | Riesgo residual: 2×3=6 → Aceptable. Responsable: Dpto. IT. Plazo: Año 1.

R3 – Phishing sobre Exchange | Nivel inicial: 12 → Residual objetivo: 4

Medidas propuestas: sustitución del filtro antispam de serie por solución con sandbox; configuración SPF, DKIM y DMARC en el dominio de correo; simulaciones internas semestrales. El incidente de phishing al competidor logístico de septiembre se utilizará como caso real en las sesiones de concienciación (proyecto O2 del PDS).

Justificación técnica: El filtrado con sandbox reduce la entrada de correos maliciosos. Las configuraciones de autenticación reducen suplantación. La formación disminuye la probabilidad asociada al factor humano.

Resultado esperado: Probabilidad: 4 → 2 | Impacto: 3 → 2 | Riesgo residual: 2×2=4 → Aceptable. Responsable: Dpto. IT + Dpto. Administración. Plazo: Año 1.

R4 – Acceso indebido en AD | Nivel inicial: 8 → Residual objetivo: 3

Medida inmediata (coste cero): desactivación de las 3 cuentas de ex-empleados identificadas. Esto debería ejecutarse esta semana, no al finalizar el análisis. El KPI-02 de las Políticas (revocación <2 horas tras baja) debe empezar a medirse y cumplirse.

Medidas adicionales: revisión trimestral de grupos privilegiados; separación de cuentas admin/usuario; auditoría avanzada de eventos en AD.

Justificación técnica: La reducción de privilegios disminuye probabilidad de abuso interno. La auditoría mejora la detección temprana y limita la degradación potencial.

Resultado esperado: Probabilidad: 2 → 1 | Impacto: 4 → 3 | Riesgo residual: 1×3=3 → Aceptable. Responsable: CISO + Dpto. IT. Plazo: cuentas inactivas inmediato; resto Año 2.

R5 – Ransomware sobre backups | Nivel inicial: 10 → Residual objetivo: 3

Medidas propuestas: repositorio de backup aislado de la red corporativa; MFA en consola de backup; pruebas independientes de restauración trimestrales. La cadencia trimestral de tests es la única forma de verificar que los backups son realmente recuperables —garantía que el Plan de Respuesta ante Incidentes da por sentada pero que actualmente no existe.

Justificación técnica: El aislamiento reduce la probabilidad de cifrado directo. El MFA protege la consola administrativa. Las pruebas garantizan recuperación real.

Resultado esperado: Probabilidad: 2 → 1 | Impacto: 5 → 3 | Riesgo residual: 1×3=3 → Aceptable. Responsable: Dpto. IT. Plazo: Año 1.

R6 – Fallo eléctrico prolongado | Nivel inicial: 8 → Residual objetivo: 3

Medida urgente: sustitución de la batería del SAI antes del verano, como indicó el técnico. Esta medida no puede esperar al plan. Medidas adicionales: configuración de apagado automático controlado del entorno virtualizado cuando el SAI alcance umbral crítico, evitando corrupción de datos; evaluación de grupo electrógeno o contrato de suministro alternativo.

Justificación técnica: El SAI con autonomía garantizada reduce el impacto en integridad y disponibilidad. El apagado controlado evita corrupción de datos. La redundancia reduce la probabilidad de interrupción total.

Resultado esperado: Probabilidad: 2 → 1 | Impacto: 4 → 3 | Riesgo residual: 1×3=3 → Aceptable. Responsable: Gerencia + Dpto. IT. Plazo: batería urgente; resto Año 2.

R8 – Brecha en proveedor cloud SaaS | Nivel inicial: 8 → Residual objetivo: 3

Medidas propuestas: incluir cláusulas de seguridad en la renovación de contrato de marzo (si la renovación llega antes de aplicar esta medida, retrasar la firma hasta tener las cláusulas incorporadas); exigir certificación ISO 27001 o equivalente; cifrar previamente los datos subidos al servicio. Alineado con el proyecto O6 del PDS.

Justificación técnica: La revisión contractual reduce la incertidumbre. El cifrado previo limita el impacto en caso de incidente externo.

Resultado esperado: Probabilidad: 2 → 1 | Impacto: 4 → 3 | Riesgo residual: 1×3=3 → Aceptable. Responsable: CISO + Asesoría Legal. Plazo: antes de renovación de contrato.

R10 – Error de configuración en firewall | Nivel inicial: 9 → Residual objetivo: 4

Medidas propuestas: procedimiento formal de gestión de cambios en dispositivos de red con registro de cambios aplicados (proyecto T1 del PDS); revisión por pares obligatoria antes de aplicar cambios en producción; auditoría completa de las reglas 'temporales' del FortiGate —las 12 que llevan años activas sin que nadie sepa bien para qué son—.

Justificación técnica: El control formal reduce la probabilidad de error. La revisión por pares limita la exposición accidental.

Resultado esperado: Probabilidad: 3 → 2 | Impacto: 3 → 2 | Riesgo residual: 2×2=4 → Aceptable. Responsable: Dpto. IT. Plazo: Año 2.

R11 – Ataque DDoS | Nivel inicial: 8 → Residual objetivo: 6

Medidas propuestas: servicio de mitigación DDoS del ISP; rate limiting en el portal de seguimiento; implementación de reverse proxy.

Justificación técnica: La mitigación externa reduce la probabilidad de saturación efectiva. El proxy limita el impacto sobre la infraestructura interna. La probabilidad no puede reducirse drásticamente porque la exposición externa es inherente al servicio.

Resultado esperado: Probabilidad: 2 → 2 | Impacto: 4 → 3 | Riesgo residual: 2×3=6 → Aceptable. Responsable: Dpto. IT + Operaciones. Plazo: Año 2.

R12 – Malware por adjunto de correo | Nivel inicial: 12 → Residual objetivo: 4

Medidas propuestas: bloqueo de extensiones ejecutables (.exe, .bat, .ps1); restricción de PowerShell para usuarios no técnicos; antimalware con análisis heurístico en tiempo real; formación continua sobre reconocimiento de adjuntos sospechosos.

Justificación técnica: El bloqueo técnico reduce la probabilidad de ejecución directa. La restricción de scripting limita la propagación interna. La formación reduce la probabilidad asociada al factor humano.

Resultado esperado: Probabilidad: 4 → 2 | Impacto: 3 → 2 | Riesgo residual: 2×2=4 → Aceptable. Responsable: Dpto. IT. Plazo: Año 1.

III. Riesgos Ampliamente Aceptables (Nivel inicial ≤ 6)

R7 – Incendio en CPD | Nivel inicial: 5 → Residual objetivo: 4

La probabilidad ya es muy baja. Las mejoras propuestas son de bajo coste y reducen el impacto potencial: detector térmico específico en sala CPD (distinto del detector de humo general de la oficina); extintores CO_2 en lugar de los de polvo actuales (los de polvo dañarían el hardware); copia de seguridad externa fuera de las instalaciones.

Justificación técnica: Estas medidas reducen el impacto físico y mejoran la capacidad de recuperación, aunque la probabilidad ya es muy baja.

Resultado esperado: Probabilidad: 1 → 1 | Impacto: 5 → 4 | Riesgo residual: 1×4=4 → Aceptable. Responsable: Gerencia. Plazo: Año 3.

8.3 Análisis del riesgo residual global

Tras la aplicación de las medidas previstas, todos los escenarios inicialmente inaceptables se sitúan dentro de la franja ampliamente aceptable según los umbrales definidos. Los riesgos intermedios reducen su probabilidad o impacto hasta niveles coherentes con el apetito de riesgo establecido.

ID	Escenario	Nivel Inicial	Clasif. Inicial	Nivel Residual	Clasif. Final
R2	Ransomware BD ERP	15	Inaceptable	6	Aceptable
R9	Filtración datos personales	15	Inaceptable	6	Aceptable
R1	Ransomware ERP	12	Intermedio	6	Aceptable
R3	Phishing	12	Intermedio	4	Aceptable
R12	Malware por adjunto	12	Intermedio	4	Aceptable
R5	Ransomware backups	10	Intermedio	3	Aceptable
R10	Error firewall	9	Intermedio	4	Aceptable
R4	Acceso indebido AD	8	Intermedio	3	Aceptable
R6	Fallo eléctrico	8	Intermedio	3	Aceptable

ID	Escenario	Nivel Inicial	Clasif. Inicial	Nivel Residual	Clasif. Final
R8	Brecha proveedor SaaS	8	Intermedio	3	Aceptable
R11	DDoS	8	Intermedio	6	Aceptable
R7	Incendio CPD	5	Aceptable	4	Aceptable

No obstante, se mantiene una concentración estructural en torno a la base de datos ERP, el sistema de copias de seguridad y el CPD local. Aunque el riesgo numérico residual es aceptable, estos activos continúan siendo nodos críticos cuya protección dependerá de la correcta implantación y mantenimiento de los controles definidos.

> **Nota del analista:** El principal riesgo no tratado en este análisis no es técnico: es la dependencia de dos personas para mantener toda la infraestructura crítica. Ninguna medida tecnológica resuelve eso. Se recomienda incorporar en la planificación del Año 2 del PDS la documentación formal de procedimientos críticos, formación cruzada entre Marcos y Ana, y explorar opciones de soporte externo para escenarios de indisponibilidad del equipo IT.

Se establece revisión anual del análisis y revisión extraordinaria ante cambios relevantes: migraciones a cloud, modificación del ERP, ampliación de servicios expuestos a internet o cambios en el equipo IT.

8.4 Integración con el Plan Director de Seguridad

Las medidas derivadas del presente análisis se incorporarán formalmente al Plan Director de Seguridad como líneas de actuación priorizadas. Esta integración asegura coherencia entre análisis, planificación y ejecución, reforzando la madurez del sistema de gestión de la seguridad de la organización.

Las mejoras técnicas (EDR, segmentación, endurecimiento de backups, revisión eléctrica) se integran como proyectos de infraestructura con planificación temporal y asignación presupuestaria en el Año 1 del PDS, reforzando y completando los proyectos T1 y T2 ya planificados. Las medidas organizativas (gestión de privilegios, procedimiento de cambios, formación en phishing y protección de datos) se incorporan al plan anual de actividades de seguridad reforzando los proyectos O1, O2 y O3. Las obligaciones contractuales con proveedores se revisarán en el marco del proyecto O6 de gestión de terceros. De este modo, el análisis de riesgos no se concibe como un documento aislado, sino como herramienta de priorización estratégica dentro del modelo de gobernanza ya existente.

9. Conclusiones

El análisis de riesgos realizado ha permitido identificar, evaluar y priorizar de forma estructurada los escenarios que pueden comprometer la seguridad de la información y la continuidad operativa de XYZ S.L. El análisis confirma lo que el incidente de octubre ya apuntaba: XYZ S.L. tiene una dependencia tecnológica elevada concentrada en activos sin redundancia. La cadena ERP → BD → almacenamiento → CPD es frágil en varios puntos simultáneamente. Y la fragilidad no es teórica: el NAS tiene síntomas físicos de degradación, el SAI tiene la batería sin cambiar, el hipervisor lleva tres meses sin parchear, los backups no han sido testados en más de un año, y hay tres cuentas de ex-empleados activas en AD que deberían llevar meses desactivadas.

Uno de los principales resultados del análisis es la confirmación de una concentración estructural de criticidad en torno al ERP corporativo, la base de datos asociada y el sistema de copias de seguridad. Estos activos no solo presentan valores elevados en el BIA, sino que actúan como nodos centrales dentro de la arquitectura organizativa. Su afectación generaría impactos en cascada sobre el servicio logístico, la facturación y la relación con clientes y proveedores.

Los dos riesgos inaceptables (R2 y R9, nivel 15) tienen en común que afectan a datos personales de clientes bajo RGPD y a la continuidad del ERP. No es casualidad: son los activos más críticos del BIA y los más expuestos al tipo de amenazas que ya están activas en el sector y en la propia organización. El ransomware sobre la BD y la filtración de datos personales no son escenarios de ciencia ficción; son escenarios que ocurren a empresas del mismo tamaño y sector con regularidad, como el competidor local de septiembre demostró.

Desde la perspectiva legal y reputacional, la información de clientes se consolida como uno de los activos más sensibles. La protección de datos personales no solo responde a una exigencia normativa (RGPD), sino que constituye un elemento determinante para la continuidad y sostenibilidad del negocio. La combinación de alta criticidad en confidencialidad y exposición a amenazas como ransomware o error humano justificó su priorización en el tratamiento.

La clasificación resultó en dos riesgos inaceptables (nivel 15), nueve en zona intermedia (niveles 8-12) y uno aceptable (nivel 5). Tras la aplicación de las medidas definidas, todos los escenarios se sitúan en niveles iguales o inferiores a 6. Esta reducción no se basa en una reevaluación arbitraria, sino en la disminución justificada de probabilidad y/o impacto mediante controles técnicos y organizativos concretos.

Es necesario ser honesto sobre las limitaciones de este análisis. Es una primera iteración, basada parcialmente en información obtenida de forma informal. Las valoraciones de probabilidad tienen un margen de incertidumbre que solo se reducirá con datos históricos de incidencias y un segundo ciclo de revisión. Un análisis más maduro requeriría al menos dos iteraciones anuales con registros reales de incidentes como base de validación.

El ejercicio también pone de manifiesto que XYZ S.L. parte de una base razonable en materia de seguridad: Políticas de Seguridad formalizadas, Plan Director de Seguridad con hoja de ruta 2026-2028, Plan de Respuesta ante Incidentes y sistema de backups. Esos documentos tienen valor real, pero solo si los controles que describen se ejecutan de verdad. El gap entre lo planificado y lo efectivo (backups sin test, cuentas sin desactivar, reglas del firewall sin auditar, batería del SAI sin cambiar) es exactamente lo que este análisis busca cerrar.

Las áreas de mejora prioritarias son: reforzar la segmentación de red para limitar movimientos laterales; consolidar la gestión de privilegios y la revisión periódica de accesos; mantener programas continuos de formación frente a ingeniería social; y mejorar la monitorización y la capacidad de detección temprana. Ninguna de estas medidas es técnicamente compleja. Lo que requieren es disciplina operativa y recursos.

Las prioridades inmediatas son claras y no requieren grandes recursos: desactivar las tres cuentas de AD esta semana, programar el cambio de batería del SAI antes del verano, revisar el NAS, y cifrar o eliminar el volcado CSV del equipo comercial. Todo lo demás puede esperar al plan. Esas cuatro acciones no pueden.